UNIVERSIDAD PERUANA UNIÓN · FACULTAD DE INGENIERÍA Y ARQUITECTURA · EP INGENIERÍA DE SISTEMAS

MATRIZ FORMAL DE PRUEBAS DE SEGURIDAD, AUTORIZACIÓN RBAC Y GESTIÓN DE USUARIOS

Actividad Autónoma — Sesión 10 · Lenguaje de Programación II · Ciclo IV (2026-2) · Docente: Reyna Barreto Benjamin David

Proyecto: PharmaSoft Backend	**Estudiante:** Gamarra	**Total Casos: 28**	**Casos Exitosos: 28 (100%)**
Rama: feature/seguridad-pruebas-gamarra	**Fecha:** 18 de octubre de 2026	**Base + Propios:** 16 + 4 = 20	**Endpoints Parte B:** 8 Casos

ID	Grupo	Usuario / token	Petición	Resultado esperado (código y mensaje)	Resultado obtenido	Estado	Evidencia
A-01	Autenticación	admin, vendedor, almacen, supervisor	POST /api/v1/auth/login	200 OK; cada respuesta trae sus roles y sus permisos; la supervisora, la unión de VENDEDOR y ALMACENERO.	200 OK. Admin: [ROLE_ADMIN] (8 perm); Vendedor: [ROLE_VENDEDOR] (4 perm); Almacen: [ROLE_ALMACENERO] (3 perm); Supervisor: [ROLE_SUPERVISOR] (7 perm).	**Pasa**	*A-01_login_roles.png*
A-02	Autenticación	Usuario inexistente / Clave incorrecta	POST /api/v1/auth/login	401 Unauthorized con el mismo mensaje en ambos casos («Credenciales inválidas»).	401 Unauthorized; {"message": "Credenciales inválidas"} idéntico en ambos casos, sin revelar si el usuario existe.	**Pasa**	*A-02_login_invalido.png*
A-03	Autenticación	inactivo (activo=false)	POST /api/v1/auth/login	401 Unauthorized; el mensaje no revela que la cuenta existe ni su estado.	401 Unauthorized; {"message": "Credenciales inválidas"}. Respuesta indistinguible de clave incorrecta.	**Pasa**	*A-03_login_inactivo.png*
A-04	Autenticación	VENDEDOR (mayúsculas)	POST /api/v1/auth/login	200 OK; findByUsernameIgnoreCase permite login sin distinguir mayúsculas/minúsculas.	200 OK. Inicio de sesión exitoso, token JWT generado correctamente y authorities cargadas.	**Pasa**	*A-04_login_case_insensitive.png*
T-01	Token JWT	vendedor	GET /api/v1/productos (sin prefijo Bearer)	401 Unauthorized «Debe iniciar sesión para acceder a este recurso».	401 Unauthorized; {"message": "Debe iniciar sesión para acceder a este recurso"}. Filtro exige Bearer.	**Pasa**	*T-01_sin_prefijo_bearer.png*
T-02	Token JWT	vendedor	GET /api/v1/productos (carácter alterado)	401 Unauthorized «El token no es válido».	401 Unauthorized; {"message": "El token no es válido"}. Detección de firma HMAC manipulada.	**Pasa**	*T-02_token_alterado.png*
T-03	Token JWT	Token de otro secreto	GET /api/v1/productos (clave alterna)	401 Unauthorized «El token no es válido».	401 Unauthorized; {"message": "El token no es válido"}. Validación de SignatureException por JJWT.	**Pasa**	*T-03_token_otro_secreto.png*
T-04	Token JWT	Token vencido	GET /api/v1/productos (exp en pasado)	401 Unauthorized «El token ha expirado. Inicie sesión nuevamente».	401 Unauthorized; {"message": "El token ha expirado..."}. Atrapado por ExpiredJwtException.	**Pasa**	*T-04_token_expirado.png*
T-05	Token JWT	vendedor	Decodificación Base64Url (atob)	Datos correctos; ningún dato sensible en el payload.	200 OK. Claims válidos: sub, authorities, iat, exp. Sin contraseñas, hashes ni datos confidenciales.	**Pasa**	*T-05_jwt_payload_inspeccion.png*
P-01	Permisos RBAC	vendedor	POST, PUT y DELETE en /api/v1/categorias	403 Forbidden en los tres endpoints.	403 Forbidden en POST, PUT y DELETE («No tiene permisos para realizar esta operación»).	**Pasa**	*P-01_vendedor_modificar_categoria.png*
P-02	Permisos RBAC	almacen	GET /api/v1/clientes y POST /api/v1/ventas	403 Forbidden en ambos endpoints.	403 Forbidden en GET /clientes y POST /ventas por carecer de CLIENTES_GESTIONAR y VENTAS_REGISTRAR.	**Pasa**	*P-02_almacen_clientes_ventas.png*
P-03	Permisos RBAC	vendedor y almacen	GET /api/v1/reportes/productos-mas-vendidos	403 Forbidden (rechazo por @PreAuthorize).	403 Forbidden en ambos usuarios. Bloqueado en método por falta de permiso REPORTES_VER.	**Pasa**	*P-03_preauthorize_reportes.png*
P-04	Permisos RBAC	admin	Petición a módulos: productos, clientes, ventas, reportes, usuarios	2xx en todas las peticiones (200 OK).	200 OK en las 5 peticiones (/productos: 200, /clientes: 200, /ventas: 200, /reportes/*: 200, /usuarios: 200).	**Pasa**	*P-04_admin_acceso_total.png*

ID	Grupo	Usuario / token	Petición	Resultado esperado (código y mensaje)	Resultado obtenido	Estado	Evidencia
U-01	Usuarios	admin	POST /api/v1/usuarios (clave sin número y rolIds vacío)	400 Bad Request en ambos (número obligatorio en clave; al menos un rol).	400 Bad Request en ambos intentos. Validación Bean Validation @Pattern y @NotEmpty activada.	**Pasa**	*U-01_validacion_password_roles.png*
U-02	Usuarios	admin	POST /api/v1/usuarios (empleado repetido y alta María Huamán)	409 Conflict (relación 1 a 1) y luego 201 Created; respuesta sin clave, hash BCrypt en BD.	409 Conflict en empleado duplicado; 201 Created para María Huamán con hash BCrypt sin exponer clave.	**Pasa**	*U-02_usuario_unicidad_alta.png*
C-01	CORS Preflight	SPA (Origin: localhost:4200)	OPTIONS /api/v1/productos	Verificación responde 200 y petición real 200 o 401, nunca error CORS.	200 OK. Header Access-Control-Allow-Origin: http://localhost:4200 y métodos permitidos enviados.	**Pasa**	*C-01_cors_preflight.png*
A-05	Autenticación (Propio)	vendedor (con espacios)	POST /api/v1/auth/login (username con espacios)	200 OK; normalización con .trim() permite login sin rechazar por espacios accidentales.	200 OK. Token generado exitosamente tras sanear el username en el request.	**Pasa**	*A-05_login_trim_espacios.png*
T-06	Token JWT (Propio)	Sin token	GET /api/v1/auth/me (sin header Authorization)	401 Unauthorized «Debe iniciar sesión para acceder a este recurso».	401 Unauthorized; filtro de seguridad intercepta la petición anónima al endpoint protegido.	**Pasa**	*T-06_auth_me_sin_token.png*
P-05	Permisos (Propio)	almacen	DELETE /api/v1/clientes/1	403 Forbidden «No tiene permisos para realizar esta operación».	403 Forbidden; el rol ALMACENERO carece de autorización para eliminar clientes.	**Pasa**	*P-05_almacen_delete_cliente.png*
U-03	Usuarios (Propio)	admin	POST /api/v1/usuarios (empleadoId: 999 inexistente)	404 Not Found «Empleado no encontrado con id: 999».	404 Not Found; {"message": "Empleado no encontrado con id: 999"}. Evita registros huérfanos.	**Pasa**	*U-03_usuario_empleado_inexistente.png*
B-01	Contraseña (B1)	vendedor	PUT /api/v1/auth/password (clave actual y nueva válidas)	204 No Content; actualización segura con BCrypt y log INFO sin clave.	204 No Content. Contraseña persistida en hash BCrypt; log registra auditoría sin exponer claves.	**Pasa**	*B-01_cambio_password_exito.png*
B-02	Contraseña (B1)	vendedor	PUT /api/v1/auth/password (clave actual errónea)	409 Conflict «La contraseña actual no es correcta».	409 Conflict; {"message": "La contraseña actual no es correcta"}.	**Pasa**	*B-02_password_actual_incorrecta.png*
B-03	Contraseña (B1)	vendedor	PUT /api/v1/auth/password (clave nueva igual a actual)	409 Conflict «La nueva contraseña debe ser distinta de la actual».	409 Conflict; {"message": "La nueva contraseña debe ser distinta de la actual"}.	**Pasa**	*B-03_password_nueva_igual_actual.png*
B-04	Contraseña (B1)	vendedor	PUT /api/v1/auth/password (clave nueva corta)	400 Bad Request por validación @Size y/o @Pattern.	400 Bad Request; {"validationErrors": {"passwordNueva": "La contraseña debe tener entre 8 y 72 caracteres"}}.	**Pasa**	*B-04_password_nueva_invalida.png*
B-05	Roles (B2)	admin	PUT /api/v1/usuarios/2/roles (rolIds: [] vacío)	400 Bad Request «Debe asignar al menos un rol».	400 Bad Request; {"validationErrors": {"rolIds": "Debe asignar al menos un rol"}}.	**Pasa**	*B-05_roles_vacio.png*
B-06	Roles (B2)	admin	PUT /api/v1/usuarios/999/roles o rolIds: [999]	404 Not Found («Usuario no encontrado» o «Roles no encontrados»).	404 Not Found; {"message": "Usuario no encontrado con id: 999"} / {"message": "Roles no encontrados: [999]"}.	**Pasa**	*B-06_usuario_rol_inexistente.png*
B-07	Roles (B2)	admin	PUT /api/v1/usuarios/1/roles (admin intenta quitarse ADMIN)	409 Conflict «Un administrador no puede quitarse a sí mismo el rol de administrador».	409 Conflict; {"message": "Un administrador no puede quitarse a sí mismo el rol de administrador"}.	**Pasa**	*B-07_admin_quitar_rol_admin.png*
B-08	Estado (B3)	admin / vendedor	PATCH /api/v1/usuarios/1/estado (false) y /2/estado (false)	409 Conflict en admin a sí mismo; 200 OK al desactivar a otro, invalidando su token previo (401) y login (401).	409 Conflict en admin a sí mismo; al desactivar vendedor, su token previo responde 401 y login responde 401.	**Pasa**	*B-08_activar_desactivar_usuario.png*

Detalle de Casos Propios Diseñados:

A-05: Verifica que espacios en blanco accidentales en username (' vendedor ') sean saneados mediante .trim() evitando rechazos falsos.
T-06: Valida que peticiones sin header Authorization a endpoints sensibles como /auth/me se intercepten de inmediato con 401.
P-05: Asegura el principio de mínimo privilegio impidiendo que ALMACENERO ejecute DELETE en el catálogo de clientes (403 Forbidden).
U-03: Garantiza integridad referencial rechazando creación de usuarios con empleadoId: 999 con 404 Not Found antes de persistir.